

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (OWASP Dependency-Check + Gripe) · Generated 2026-06-11 · Source SHA: 229a7ee

Summary (pre-remediation scan)

Metric	Count
Total CVE entries found	141
CRITICAL dependencies	2
HIGH dependencies	7
MEDIUM dependencies	0
Supply-chain alerts	2 (typosquat + untrusted HTTP repo)

Known-vulnerable dependencies

#	Dependency	Version	Top CVE	CVSS	Severity	CVE Coun
1	com.fasterxml.jackson.core:jackson-databind	2.9.8	CVE-2019-14379	9.8	CRITICAL	107
2	org.apache.logging.log4j:log4j-core	2.14.1	CVE-2021-44228	10.0	CRITICAL	15
3	mysql:mysql-connector-java	8.0.30	CVE-2023-22102	8.3	HIGH	2
4	commons-io:commons-io	2.4	GHSA-78wr-2p64-hpwj	7.5	HIGH	4
5	org.apache.logging.log4j:log4j-api	2.14.1	CVE-2026-34479	7.5	HIGH	2
6	com.google.guava:guava	24.1.1-jre	CVE-2023-2976	7.1	HIGH	4
7	com.google.protobuf:protobuf-java	3.19.4	CVE-2024-7254	8.7	HIGH	4

8	com.fasterxml.jackson.core:jackson-annotations	2.9.0	CVE-2018-1000873	6.5	HIGH	1
9	org.apache.commons:commons-lang3	3.4	GHSA-j288-q9x7-2f5v	6.5	HIGH	2

Critical CVE detail

CVE	Dependency	CVSS	Severity	Description
CVE-2021-44228	log4j-core 2.14.1	10.0	CRITICAL	Log4Shell — JNDI lookup RCE; any attacker-controlled log message triggers remote code execution
CVE-2021-45046	log4j-core 2.14.1	9.0	CRITICAL	Context lookup RCE bypass for CVE-2021-44228
CVE-2019-14379	jackson-databind 2.9.8	9.8	CRITICAL	Deserialization gadget chain via SubTypeValidator
CVE-2019-14540	jackson-databind 2.9.8	9.8	CRITICAL	Deserialization via c3p0 gadget
CVE-2020-36518	jackson-databind 2.9.8	7.5	HIGH	Stack overflow via deeply nested JSON
CVE-2024-7254	protobuf-java 3.19.4	8.7	HIGH	Recursive message causing stack overflow / DoS
CVE-2023-22102	mysql-connector-java 8.0.30	8.3	HIGH	MitM vulnerability in connector protocol handshake

Supply-chain alerts

CRITICAL — Typosquatted dependency. `com.fastxml.jackson.core:jackson-databind:2.9.8` impersonates the legitimate `com.fasterxml.jackson.core`; the coordinate does not exist on Maven Central. **Removed in this PR.**

HIGH — Untrusted repository. `http://insecure-mirror.example.net/maven2` is a plain-HTTP Maven repository (MITM artifact-injection risk). **Removed in this PR.**

Machine-readable source: `depscan-report.json` (141 CVE entries, Grype + OWASP). Generated by the Dependency & Supply-Chain Plugin — Stage 1 run 2026-06-11.